

Meetifyy Security Remediation Report

Security findings, remediation status, and validation results

Scope

Repository: Meetifyyyy/Meetifyy

This report documents the security findings identified during the repository scan and the fixes applied in this branch.

Remediated Findings

1. Unauthenticated local direct upload and path traversal

The local fallback upload endpoint accepted anonymous requests and used a user-controlled object key as a filesystem path.

Remediation:

- Added JWT authentication.
- Required the key to belong to an existing media record owned by the authenticated user.
- Restricted keys to a safe folder/filename format.
- Resolved paths and enforced the uploads-directory boundary.
- Added a 25 MB request-size limit, including chunked requests.

2. Unauthenticated bulk signed URLs

The signed URL endpoint accepted arbitrary object keys without authentication or authorization.

Remediation:

- Added JWT authentication.
- Limited requests to 100 validated keys.
- Limited URL expiry to 60 seconds through 1 hour.
- Returned URLs only for public media or media owned by the authenticated user.

3. Weak upload validation

Uploads had no server-side size limit and derived storage extensions from the original filename.

Remediation:

- Added a 25 MB Multipart limit.
- Allowed only supported image, video, and audio MIME types.
- Restricted upload folders.
- Derived stored extensions from the validated MIME type.
- Sanitized provider-generated extensions.

4. Link-preview SSRF exposure

The link preview service relied on a partial hostname blocklist and followed redirects.

Remediation:

- Resolved hostnames before fetching.
- Blocked loopback, private, link-local, multicast, and reserved IPv4/IPv6 targets.
- Rejected localhost-style hostnames.
- Disabled redirects.
- Enforced a 5-second timeout and 1 MB streamed response limit.

5. Admin CSRF validation bypass

Mutating admin requests could omit the CSRF cookie and bypass the previous conditional check.

Remediation:

- Required both the CSRF cookie and matching X-CSRF-Token header for mutating requests.

6. Broad production CORS and CSP

Production CORS allowed arbitrary Vercel subdomains, and the CSP used broad wildcard destinations and unsafe script directives.

Remediation:

- Production CORS now allows only exact CORS_ORIGINS values.
- Development CORS permits only localhost and loopback origins.
- Removed unsafe-inline and unsafe-eval from script-src.
- Replaced broad image/connect wildcards with explicit sources.

7. Dependency advisories

React Router was upgraded to 7.18.2 in both frontend applications and lockfiles were refreshed.

The current npm advisory database still reports the React Router RSC-mode CSRF advisory for 7.18.2. Meetify uses Vite client-side routing and does not use React Router RSC/server actions. This should be rechecked when a Router release containing the advisory fix is published.

Validation

- Backend production build: passed.
- Main frontend production build: passed.
- Admin frontend production build: passed.
- Backend production dependency audit: 0 vulnerabilities.
- Frontend dependency audit: Router RSC advisory remains, as noted above.
- Admin frontend dependency audit: Router RSC advisory remains, as noted above.
- Backend Jest suite: 2 suites passed, 7 suites failed because existing tests do not provide required NestJS dependencies such as PrismaService, SupabaseService, and BlocksService.

Changed Files

- backend/src/uploads/uploads.controller.ts
- backend/src/uploads/uploads.service.ts
- backend/src/uploads/providers/supabase-storage.provider.ts
- backend/src/uploads/providers/cloudflare-r2.provider.ts
- backend/src/link-preview/link-preview.service.ts
- backend/src/common/guards/admin-jwt.guard.ts
- backend/src/main.ts
- frontend/src/shared/utils/mediaPipeline.js
- Frontend and backend package manifests and lockfiles